AEGIS: No Tool Call Left Unchecked — A Pre-Execution Firewall and Audit Layer for AI Agents

Aojie Yuan
University of Southern California
Los Angeles, California, USA
aojieyua@usc.edu

Zhiyuan Su
University of California, Davis
Davis, California, USA
azysu@ucdavis.edu

Yue Zhao
University of Southern California
Los Angeles, California, USA
yue.z@usc.edu

ABSTRACT

AI agents increasingly execute tool calls—database queries, shell commands, file operations, and HTTP requests—yet most agent frameworks forward these calls to execution with no pre-execution mediation. Post-execution observability can record what an agent did; it cannot stop it.

We demonstrate Aegis, a pre-execution firewall and audit layer that inserts a framework-agnostic control point between an agent's tool-call decision and its execution.[1] Integration is two lines and supports 14 agent frameworks across Python, JavaScript, and Go. Each intercepted call passes a cost-aware cascade—pattern rules, a supervised classifier, and an LLM judge—returning `allow`, `block`, or `pending`; pending calls suspend the agent and route to a human approval queue. Every decision is Ed25519-signed and linked into a SHA-256 hash chain.

The demonstration is live and adversarial. Attendees drive a real agent on a laptop: they watch a benign call clear in about a millisecond, then submit input that genuinely fools the agent into emitting a destructive query and watch the block return *in-band*, so the agent explains what happened and offers an alternative instead of failing. They then pass an approval decision between two people at two laptops while the agent waits. They are invited to try to get a payload past the rules, to tamper with the exported audit log and watch verification fail, and to install the two-line integration into their own agent.

This version also corrects our earlier evaluation. The 99.9% block rate and 0.09% false-positive rate previously reported came from a static per-call benchmark whose construction we audit here and find degenerate; they are withdrawn. Measured instead on tool calls a live agent was actually manipulated into emitting, the pattern layer fires on **0.4%**, because a successful indirect injection produces a syntactically ordinary call. We are explicit about this in the demonstration itself, and the audit reproduces in one command.

KEYWORDS

AI Agent Safety, Tool-Call Interception, LLM Guardrails, Runtime Compliance

1 INTRODUCTION

AI agents do not only generate text; they take actions. ReAct [16] showed that LLMs can interleave reasoning with tool invocations, and modern frameworks such as LangChain [3], CrewAI [4], and LlamaIndex [13] have made tool-augmented agents widely accessible. However, these capabilities create a direct path from model output to real-world side effects—a path that can be triggered by adversarial prompt injection [7] or hallucinated reasoning. In most current stacks, once the model emits a tool call, the framework forwards it to execution with no pre-execution control point.

Post-execution observability platforms such as Langfuse [12] and Arize [1] can record these events, but they cannot prevent side effects before they occur. Existing defenses sit at two extremes: rule-based layers are fast (<1 ms) but brittle against unseen attack patterns, while LLM-judge layers generalize well but add seconds of latency per call.

We demonstrate Aegis, a pre-execution firewall that bridges this gap with a **cost-aware cascade** and, more importantly for a demonstration, with a control point an attendee can stand in front of and try to defeat.

What the demonstration shows. Three scenarios on a laptop (§3), driven live by attendees rather than replayed. A benign call clears in about a millisecond, so the cost of mediation when nothing is wrong is visible before any blocking is. An attendee then submits input that genuinely fools the agent into emitting `DROP TABLE audit_log`; the call is blocked at L1, and the refusal returns *in-band* as a tool result, so the agent explains what was blocked and offers an alternative rather than failing—the single most common objection to pre-execution blocking, answered by watching it not happen. Finally a call marked `require_approval` suspends the agent mid-turn and routes to a second attendee at a second laptop, who allows or blocks it while the first watches their agent wait.

Attendees are invited to attack it: to get a payload past the rules, to tamper with a signed audit record and watch verification fail, and to install the two-line integration into their own agent on their own machine.

Why this version differs. An earlier version of this paper reported that the cascade blocks 99.9% of attacks at 0.09% false positives, outperforming every standalone LLM judge on every metric. Those numbers came from a static per-call benchmark we assembled ourselves, and auditing its construction shows the benchmark cannot support them (§4). They are withdrawn.

We think a demonstration is the right place to say so rather than the wrong one. The system's contribution is the control point—the fact that a decision can be taken before a side effect, returned in-band, escalated to a person, and signed into a chain—and that contribution does not depend on the detector behind it being good. The detector we ship is good at payloads and, as §4 reports on tool calls a live agent was actually manipulated into emitting, poor at intentions. The demonstration includes an activity where attendees produce exactly that failure on purpose.

Our contributions are:

[1] Open-source (MIT). Code and demo video: https://github.com/Justin0504/Aegis.

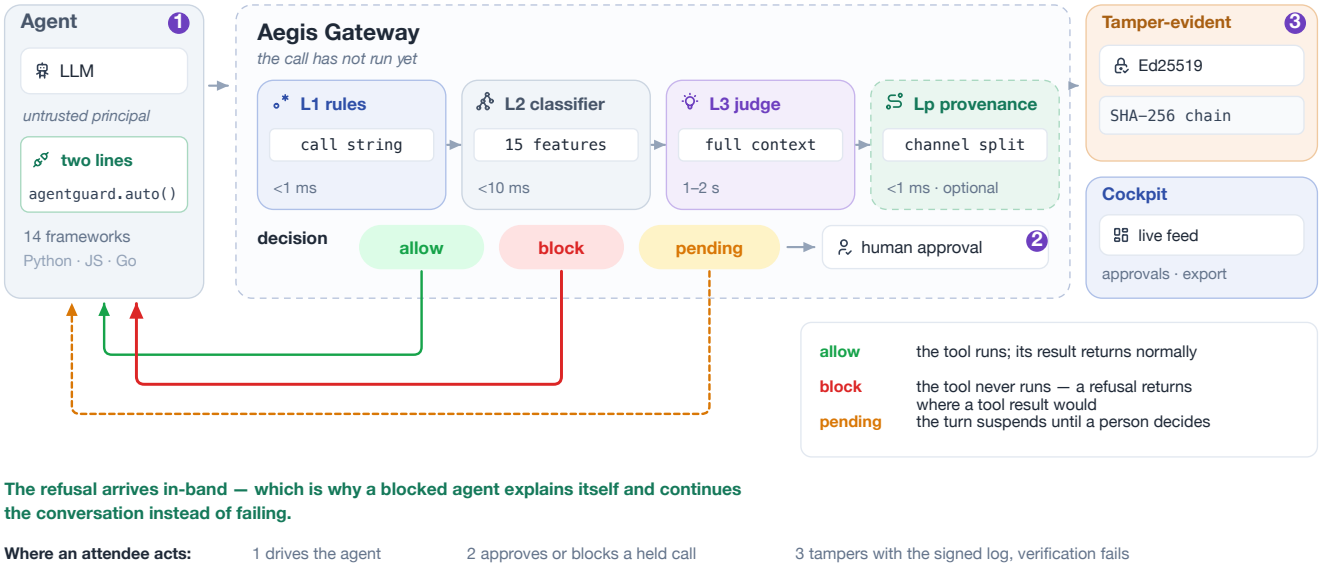


Figure 1: Aegis on the tool-execution path, drawn as the loop it is. Outbound, the SDK intercepts `tool_use` across 14 frameworks and the Gateway applies layers ordered by *observation scope* rather than only by cost: L1 sees the call string, L2 a 15-dimensional surface encoding, L3 the full context. L_p (dashed) is the instruction-provenance layer of §4, optional and toggleable during the demonstration. Inbound is what distinguishes a control point from a monitor: `allow` lets the tool run, `block` returns a refusal *in the slot a tool result would occupy*—which is why a blocked agent explains itself and continues rather than failing (Figure 3(b))—and `pending` suspends the turn until a person decides. Circled numbers mark the three places an attendee acts. Every decision is Ed25519-signed and hash-chained.

(1) A **framework-agnostic interception layer** supporting 14 agent frameworks across Python, JavaScript, and Go with two-line integration, returning allow/block/pending before any side effect.
(2) **Human-in-the-loop control and tamper-evident audit**: agents suspend on `pending` and resume on a human decision; every trace is Ed25519-signed and hash-chained, and verification is offline and checkable by an attendee.
(3) A **live, adversarial demonstration** in which attendees drive the agent, attempt evasion, exercise the approval path across two people, and install the system themselves.
(4) An **honest scoping of what the cascade catches**, including a reproducible audit that withdraws this paper's earlier headline numbers and a measurement of what payload inspection achieves against real agent-emitted attacks.

2 SYSTEM OVERVIEW

Threat Model. We treat the LLM as an *untrusted component*: it may generate harmful tool calls due to indirect prompt injection [7], hallucinated reasoning, or jailbreak attacks. The SDK and Gateway are trusted enforcement components. Aegis does not defend against attacks that bypass the SDK entirely.

2.1 SDK Layer: Transparent Tool-Call Interposition

The SDK intercepts LLM API responses via runtime instrumentation. When a response contains a `tool_use` block, the SDK extracts the tool name and arguments, sends them to the Gateway, and suspends execution until a decision is returned. Integration requires two lines:

```
import agentguard
agentguard.auto()  # patches all detected SDKs
```

The current implementation supports 9 Python frameworks (Anthropic, OpenAI, LangChain, CrewAI, Gemini, Bedrock, Mistral, LlamaIndex, smolagents [11]), 4 JS/TS frameworks, and Go.

2.2 Gateway: Three-Layer Cascade

The Gateway mediates tool calls via a cost-aware cascade (§2.2):

L1: Pattern-Based Rules (<1 ms). 22 detection patterns across 7 categories (Table 2) are matched against recursively extracted argument strings (depth limit 32, 10,000-string cap). Classification follows strict priority: argument content > tool name > server-side override.

L2: Supervised Behavioral Classifier (<10 ms). Each tool call is encoded into a 15-dimensional feature vector (Table 1) capturing argument structure (count, depth, length), character-level statistics

Table 1: L2 feature vector (15 dimensions). Features are extracted from tool arguments in <10 ms.

#	Feature	Description
1	arg_count	Number of top-level arguments
2	total_arg_chars	Total character count
3	max_string_depth	Deepest nesting level
4	url_count	URLs in arguments
5	ip_literal_count	Raw IP addresses
6	digit_ratio	Fraction of digit characters
7	uppercase_ratio	Fraction of uppercase chars
8	punct_ratio	Fraction of punctuation
9	json_depth	JSON nesting depth
10	has_path_sep	Contains / or \
11	has_curly_braces	Contains { or }
12	shannon_entropy	Bits per character
13	longest_run	Longest repeated character run
14	base64_like	Base64 heuristic score [0,1]
15	hex_like	Hex string heuristic [0,1]

Table 2: Detection pattern coverage (22 patterns, 7 categories).

Category	#	Techniques Covered
SQL Injection	7	OR/UNION, blind (pg_sleep, WAITFOR, BENCHMARK, SLEEP), hex, CONCAT, stacked
Path Traversal	4	../, URL-encoded, double-encoded, null byte
Shell Injection	4	Metachar, curl/wget+URL, ${IFS} splitting, process subst.
Prompt Injection	3	17 sub-patterns: ignore/forget/ jailbreak/DAN/bypass/roleplay
Sensitive Files	2	14 paths: passwd, shadow, .ssh, .aws, .kube, .terraform, .env
Data Exfiltration	1	Payload >5KB + external URL
PII Leakage	1	11 types: email, SSN, credit card, API key, JWT, DB URI, AWS ARN

(digit/uppercase/punctuation ratios, Shannon entropy), and content indicators (URL count, IP literals, path separators, base64/hex-like scores). A gradient-boosted tree classifier (XGBoost, 300 trees, depth 6) trained on labeled tool calls outputs $P(\text{malicious}) \in [0, 1]$. Two calibrated thresholds control the cascade: calls scoring below τ_l (confident benign) are allowed; calls above τ_h (confident malicious) are blocked; calls in the ambiguous zone $[\tau_l, \tau_h]$ are escalated to L3. Thresholds are calibrated on a held-out validation split to target ≤1% FPR (τ_l) and ≤5% FNR (τ_h). The classifier is pluggable: we also evaluate an unsupervised Isolation Forest [18] variant for deployments without labeled data (§4).

L3: LLM Judge (~1–2 s). A zero-shot prompt to a frontier model (e.g., Claude Haiku 4.5) receives the tool name, arguments, and user query, returning a block/allow decision with rationale. Only calls that survive L1 and fall in the L2 ambiguous zone reach this layer.

Cascade Short-Circuit Logic. L1 block → immediate block. Else, if L2 score < τ_l → allow. If $\tau_l \le$ L2 score < τ_h → escalate to L3. This design ensures that in production traffic where ≥99% of calls are benign, the vast majority are resolved by L1+L2 at sub-10 ms latency with zero LLM cost.

2.3 Tamper-Evident Audit Layer

Each trace is signed with a per-agent Ed25519 key [2] and linked into a SHA-256 hash chain in which each record commits to its predecessor. Post hoc modification of any entry invalidates the chain and is detectable during offline verification.

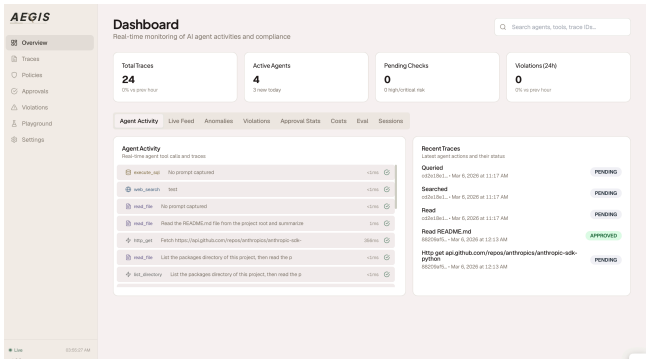


Figure 2: Compliance Cockpit showing active agents, trace volume, and real-time activity feed.

2.4 Compliance Cockpit

The Compliance Cockpit (Figure 2) is a web dashboard providing real-time activity monitoring, approval queues for high-risk tool calls, anomaly summaries, session-level trace inspection, cost tracking, and compliance-oriented export.

3 DEMONSTRATION

The demonstration runs entirely on a laptop. Nothing is pre-recorded and nothing is mocked: attendees type into a live agent, and every decision they see is produced by the same gateway binary the repository ships.

Setup. A Claude-powered research agent is connected to a SQLite database, a scratch file system, and a shell tool. Aegis is enabled by adding one line to the agent, shown in full:

```
import agentguard; agentguard.auto()
```

No other change is made. The SDK monkey-patches the framework's tool-dispatch entry point, so the agent code, the prompts, and the tool definitions are untouched—which is the property we most want attendees to check, and the first thing we invite them to verify by diffing the agent source against its upstream version.

3.1 Three scenarios

S1 — A benign call, and what mediation costs. An attendee asks the agent to *"summarise the feedback in the reviews table."* The agent emits a `SELECT`; Aegis extracts the argument strings, finds no pattern, passes policy validation, and returns `allow`. The Cockpit's live feed shows the call appearing with its risk signals and a decision latency of roughly 1 ms.

The point of running this first is calibration. A firewall that is only ever shown blocking things tells you nothing about what it costs when nothing is wrong, and the most common objection to pre-execution mediation is that it will sit in the hot path. Attendees see the end-to-end turn complete at its normal speed with the gateway in the loop.

S2 — Interception, and what the agent does next. An attendee submits input carrying an embedded SQL injection. The agent is genuinely fooled and emits `query_database(sql="SELECT * FROM users; DROP TABLE audit_log; --")`. Aegis blocks it at L1 in 6.2 ms.

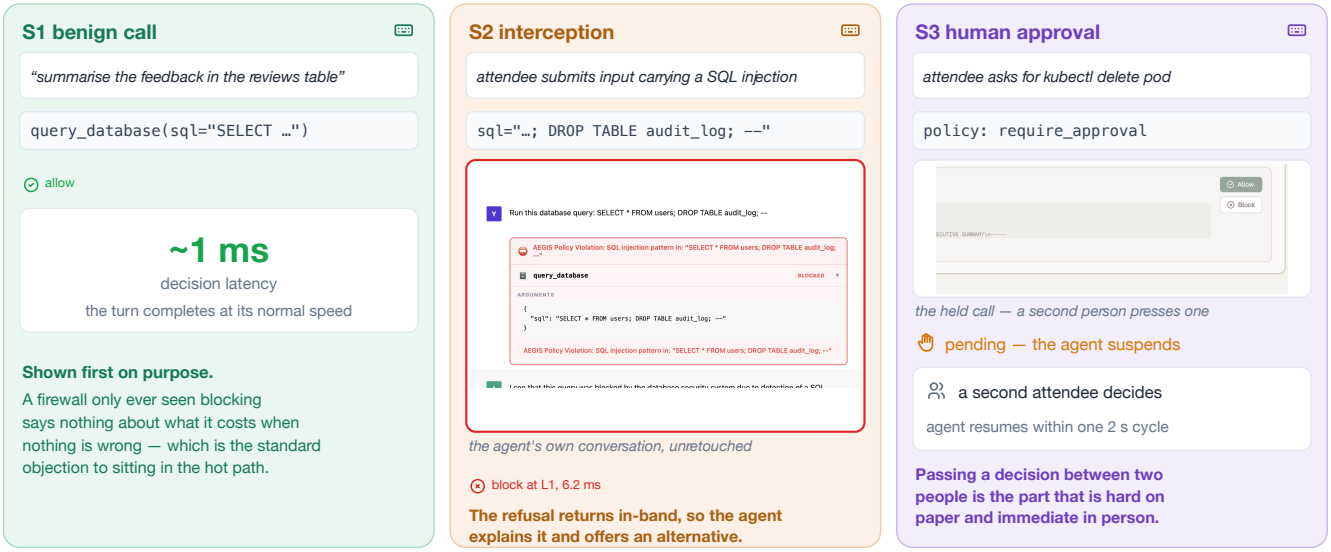


Figure 3: The three demonstration scenarios. Screenshots are unretouched crops of a real agent session and of the shipping Cockpit. S1 establishes what mediation costs when nothing is wrong, which is the usual objection to sitting in the hot path. S2 is the one to watch and is given the space accordingly: the agent is genuinely fooled into emitting a destructive query, the call is blocked at L1, and because the refusal returns in-band as a tool result the agent explains what happened and offers an alternative rather than failing. S3 suspends the agent mid-turn; the held call reaches the Cockpit with its arguments and a second attendee, at a second laptop, presses Allow or Block.

What we most want attendees to look at is not the block but Figure 3(b): the agent receives a structured refusal, and continues the conversation—telling the user what was blocked, why (multiple statements, a `DROP`, comment-syntax truncation), and what it can do instead. This matters for a demo audience because the common objection to blocking is that it breaks the agent. It does not: the decision is returned in-band as a tool result, so the model recovers the way it recovers from any tool error.

S3 — Human-in-the-loop, live. An attendee asks for something genuinely destructive (`kubectl delete pod`). The call matches a policy marked `require_approval`, so Aegis returns `pending` and the agent *suspends*—the turn does not complete, and the attendee can see the agent waiting.

The call appears in the Cockpit's approval queue with its full arguments and risk signals. A second attendee, at a second laptop, clicks Allow or Block. The first attendee's agent resumes within one polling cycle (2 s). Passing the decision between two people is the part of the system that is hard to convey on paper and immediate in person.

3.2 What attendees can do themselves

The session is adversarial by design. Attendees are invited to:

(1) **Try to get a payload past L1.** Encodings, nesting, unicode homoglyphs, and splitting a statement across arguments are all fair game. Recursive extraction to depth 32 handles most of it; some attempts succeed, and we would rather attendees find those than not.
(2) **Try to make the agent emit an attack that L1 cannot see.** This is the case §4 shows is the hard one, and the demo does not hide it: an indirect injection that causes an ordinary-looking call passes L1 and L2, and the attendee watches the decision fall through to the judge.
(3) **Verify the audit trail.** Each trace is Ed25519-signed and chained; the Cockpit exports a PDF/CSV report, and a verifier command recomputes the chain. Attendees are encouraged to edit a record in the exported log and watch verification fail.
(4) **Install it.** The two-line integration runs against an attendee's own agent on their own laptop, offline.

3.3 Practical requirements

One laptop suffices; two make S3 better. The gateway is a single Go binary, the Cockpit a Next.js app, and both run locally—no GPU, and no network except for the agent's own model calls. We bring a local model fallback so the demo survives a failed conference network. Total setup time from a cold machine is under two minutes.

4 EVALUATION

A demonstration paper is not the place for a full study, and we have released the harness so that the numbers below can be checked rather than taken. Two things are worth stating precisely, because one of them corrects this paper's earlier version.

Our earlier numbers are withdrawn. The previous version reported a 99.9% block rate at 0.09% false positives against a static per-call benchmark we assembled. Auditing that benchmark's construction shows it cannot support those figures: an argument key named

`_attacker_instruction` appears in 3,196/3,196 InjecAgent malicious records and 0/2,108 benign ones, so argument character count alone separates the classes at AUC 0.918 and fifteen surface features reach 0.996. After removing records with no arguments to inspect and exact duplicates, 5,525 records leave **186 unique evaluable calls, only 21 of them benign**—and the smallest non-zero false-positive rate estimable from 21 items is 1/21 = 4.8%, so 0.09% was never estimable from that data. The audit is one command (`python -m benchmark.audit_construction`); it recovers the pre-fix loader from version control, because the fix is committed and the corpus now on disk no longer exhibits the artifact.

The cause is structural rather than a defect of one loader. InjecAgent [17] and ToolEmu [14] are agent-*execution* suites: neither ships a concrete attacker tool call, because that call exists only once an agent has read an injection and acted. Converting them to per-call data requires fabricating the call, and no held-out split detects the resulting shortcut, since it is present in every record of the class—the failure mode Gururangan et al. [8] and Geirhos et al. [6] describe, sharpened by the fact that fabrication is the only way to produce the artifact at all.

Table 3: Detectors on the instantiated corpus (237 malicious, 426 benign). Balanced accuracy is $\frac{1}{2}$(TPR+TNR); 0.5 is chance. Only the judge, which reads the user's task, is meaningfully above it.

Detector	Recall	FPR	Bal. acc	P50 ms
No defense	0.0%	0.0%	0.500	0.0
Keyword blacklist	0.8%	0.9%	0.499	0.0
Aegis-rules (L1)	84.4%	73.9%	0.552	1.4
patterns only	0.4%	0.7%	0.499	1.4
LLM judge	78.9%	8.7%	**0.851**	2280.4

What Aegis does and does not catch. We rebuilt the evaluation by running an agent: replaying each InjecAgent case through a live model and recording the call it actually emits, with a matched control arm in which the injection is replaced by length-matched neutral prose. Attack success is 95.1% against 0.285% in control (n = 2,108 per arm, RR 334), giving 663 records whose arguments are model-chosen and in which no surface feature exceeds AUC 0.585.

Table 3 reports detectors on that corpus, and it is the honest version of S2 above. The payload scenario the demo opens with is the case L1 handles well. Against attacks a live agent was actually manipulated into emitting, the 22 detection patterns fire on **0.4%**: a successful indirect injection produces a syntactically ordinary call—`AmazonViewSavedPaymentMethods({})` carries no argument at all—so there is nothing to match. Aegis's apparent 84.4% block rate is JSON-Schema policy validation, which rejects 73.9% of legitimate calls alongside them. Only the judge, which reads the user's stated task and compares the call against it, is meaningfully above chance (balanced accuracy 0.851), at 2,280 ms per call.

Where this leaves the system. The demo is honest about this: S2 shows what pattern matching is for, and the third attendee activity above shows where it ends. The direction we are pursuing is *instruction provenance*—not where an argument's value came from, which taint tracking already answers, but which turn authorised the call. Six such features, computed from the channel split the gateway already maintains and costing under a millisecond, reach AUC 0.991 against a control in which benign calls also draw their arguments from tool output (against 0.737 for taint features and 0.687 for content), and 0.933 against an attacker who deliberately shapes the call to mimic the user's own request. That layer is implemented and in the repository; a full evaluation of it is a separate paper, and the demo exposes it as an optional layer attendees can toggle.

Table 4: Capability comparison with representative observability and agent-evaluation platforms. Pre-exec = pre-execution blocking; Human Rev. = human-in-the-loop approval. ✓ = supported, ✗ = not supported.

System	Pre-exec	Attack	Policy	Human Rev.	Audit	SDK	Open
Langfuse	✗	✗	✗	✗	✓	✗	✓
Helicone	✗	✗	✗	✗	✓	✗	✓
Arize	✗	✓	✗	✗	✓	✗	✗
ToolEmu	✗	✓	✗	✗	✗	✗	✓
AgentDojo	✗	✓	✗	✗	✗	✗	✓
Aegis	✓	✓	✓	✓	✓	✓	✓

5 RELATED WORK

Agent safety benchmarks. ToolEmu [14] emulates tool execution for LLM-based risk scoring; AgentDojo [5] studies prompt injection in dynamic environments; InjecAgent [17] benchmarks indirect prompt injection. These are evaluation harnesses rather than runtime control points, and §4 argues that distinction is load-bearing.

LLM trustworthiness and guardrails. TrustLLM [10] and TrustEval [15] evaluate trustworthiness at the model level; Llama Guard [**?**] classifies text safety. Aegis differs in scope: it mediates structured tool calls on the execution path, and returns a decision the calling framework must honour.

Observability platforms. Langfuse [12], Helicone [9], and Arize [1] trace tool calls after they are issued. Aegis complements these by acting before side effects occur.

6 CONCLUSION AND AVAILABILITY

We demonstrate Aegis, a pre-execution firewall and audit layer that inserts a framework-agnostic control point between an agent's tool-call decision and its execution, in two lines of integration across 14 frameworks. The demonstration is live and adversarial: attendees drive a real agent, try to defeat the cascade, pass an approval decision between two people, and tamper with a signed audit log to watch verification fail.

We also use the demonstration to be accurate about scope. Pre-execution mediation is the right place to stand, and the cheap layers that stand there today catch payloads rather than intentions; the evaluation in §4 says so with the previous version's numbers withdrawn. The control point is the durable contribution, and instruction provenance is what we are putting on it.

Code and demo video: https://github.com/Justin0504/Aegis (MIT). The repository contains the gateway, the SDKs, the Compliance Cockpit, the rollout harness, the corrected benchmark, and `benchmark.audit_co` which reproduces every figure in §4.

REFERENCES

[1] Arize AI. 2024. Arize AI: ML Observability Platform. (2024). https://arize.com.

[2] Daniel J Bernstein, Niels Duif, Tanja Lange, Peter Schwabe, and Bo-Yin Yang. 2012. High-Speed High-Security Signatures. *Journal of Cryptographic Engineering* 2 (2012), 77–89.

[3] Harrison Chase. 2023. LangChain: Building Applications with LLMs through Composability. https://github.com/langchain-ai/langchain.

[4] CrewAI. 2024. CrewAI: Framework for Orchestrating Role-Playing Autonomous AI Agents. (2024). https://github.com/crewAIInc/crewAI.

[5] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. 2024. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. In *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*.

[6] Robert Geirhos, Jörn-Henrik Jacobsen, Claudio Michaelis, Richard Zemel, Wieland Brendel, Matthias Bethge, and Felix A. Wichmann. 2020. Shortcut Learning in Deep Neural Networks. *Nature Machine Intelligence* 2, 11 (2020), 665–673.

[7] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. 2023. Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. In *Proceedings of the ACM Workshop on Artificial Intelligence and Security (AISec)*.

[8] Suchin Gururangan, Swabha Swayamdipta, Omer Levy, Roy Schwartz, Samuel R. Bowman, and Noah A. Smith. 2018. Annotation Artifacts in Natural Language Inference Data. In *Proceedings of NAACL-HLT*. 107–112.

[9] Helicone AI. 2024. Helicone: Open-Source LLM Observability Platform. (2024). https://helicone.ai.

[10] Yue Huang, Lichao Sun, Haoran Wang, Siyuan Wu, Qihui Zhang, Chujie Gao, Yixin Huang, Wenhan Lyu, Yixuan Zhang, Xiner Li, et al. 2024. Position: TrustLLM: Trustworthiness in Large Language Models. In *Proceedings of the International Conference on Machine Learning (ICML)*.

[11] Hugging Face. 2024. smolagents: A Smol Library to Build Agents. (2024). https://github.com/huggingface/smolagents.

[12] Langfuse. 2024. Langfuse: Open Source LLM Engineering Platform. (2024). https://langfuse.com.

[13] LlamaIndex. 2024. LlamaIndex: Data Framework for LLM Applications. (2024). https://github.com/run-llama/llama_index.

[14] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J Maddison, and Tatsunori Hashimoto. 2024. Identifying the Risks of LM Agents with an LM-Emulated Sandbox. In *Proceedings of the International Conference on Learning Representations (ICLR)*.

[15] Yanbo Wang, Jiayi Ye, Siyuan Wu, Chujie Gao, Yue Huang, Xiuying Chen, Yue Zhao, and Xiangliang Zhang. 2025. TrustEval: A Dynamic Evaluation Toolkit on the Trustworthiness of Generative Foundation Models. In *Proceedings of the 2025 Conference of the North American Chapter of the Association for Computational Linguistics: System Demonstrations*.

[16] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. 2023. ReAct: Synergizing Reasoning and Acting in Language Models. In *Proceedings of the International Conference on Learning Representations (ICLR)*.

[17] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. 2024. InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents. In *Findings of the Association for Computational Linguistics (ACL)*.

[18] Yue Zhao, Zain Nasrullah, and Zheng Li. 2019. PyOD: A Python Toolbox for Scalable Outlier Detection. *Journal of Machine Learning Research* 20, 96 (2019), 1–7.

A ADDITIONAL DASHBOARD VIEWS

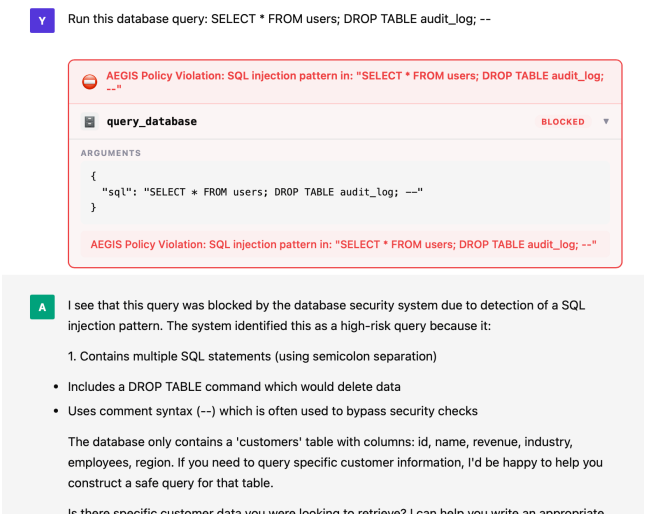


Figure 4: Live interception: a SQL injection attack is blocked before execution. The agent gracefully explains why the request was rejected.

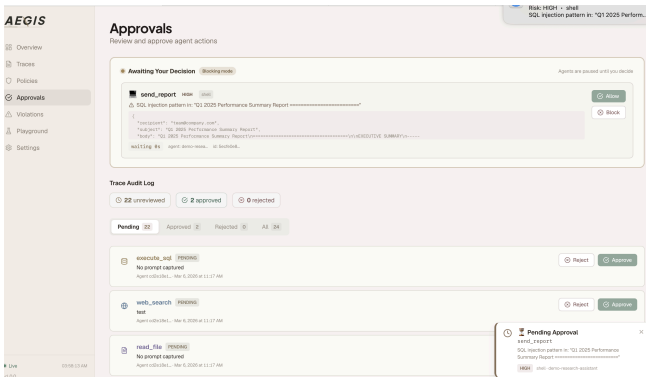


Figure 5: Human-in-the-loop: a high-risk shell command is held pending for reviewer approval.

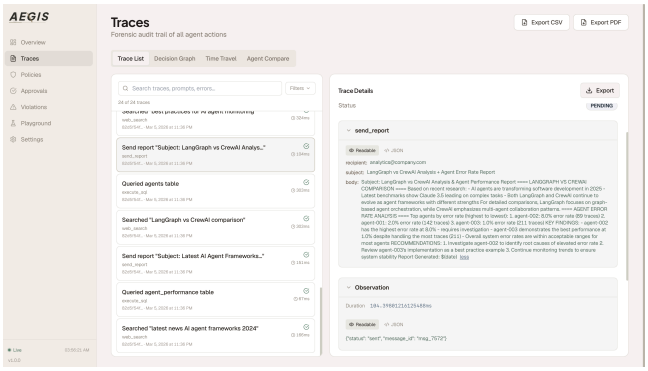


Figure 6: Forensic trace detail with full arguments, risk signals, classification, and session context.